

LLM-Assisted Cybersecurity Risk Assessment Report

Generated using Llama 3.1 + LlamaIndex RAG

R001 - Encryption key governance evidence should be reviewed

Risk Category: Data Protection

Cause: Encryption keys rotate every 90 days under a documented key management process.

Consequence: If encryption governance documentation is incomplete, the organisation may have reduced assurance over long-term key protection.

Likelihood: Medium

Impact: Medium

Risk Rating: Medium

Existing Controls: AES-256 encryption, TLS encryption and 90-day key rotation policy

Recommended Controls: Review key management procedures and recent key rotation records.

Risk Treatment: Mitigate

Residual Risk: Low

Evidence Source: RAG findings and user/vendor follow-up answers

Follow-Up Question:

R002 - Cross-border data residency compliance should be evidenced

Risk Category: Privacy and Compliance

Cause: Sensitive information is stored across Australia and Singapore, creating jurisdiction-specific privacy obligations.

Consequence: If cross-border handling requirements are not formally evidenced, privacy and regulatory compliance risks may increase.

Likelihood: Medium

Impact: High

Risk Rating: High

Existing Controls: Sensitive data stored in Australia and Singapore with encryption at rest and in transit

Recommended Controls: Review data residency agreements and validate regulatory compliance obligations.

Risk Treatment: Mitigate

Residual Risk: Low

Evidence Source: RAG findings and user/vendor follow-up answers

Follow-Up Question:

R003 - Recovery Time Objective evidence should be confirmed

Risk Category: Business Continuity

Cause: A 4-hour RTO exists for critical systems, but supporting continuity evidence should be reviewed.

Consequence: If recovery procedures are not fully evidenced, service restoration delays may occur during outages.

Likelihood: Medium

Impact: Medium

Risk Rating: Medium

Existing Controls: RTO for critical systems is 4 hours

Recommended Controls: Review continuity documentation and recovery testing evidence.

Risk Treatment: Mitigate

Residual Risk: Low

Evidence Source: RAG findings and user/vendor follow-up answers

Follow-Up Question:

R004 - Disaster recovery testing effectiveness should be evidenced

Risk Category: Business Continuity

Cause: Disaster recovery testing occurs annually and within the last 12 months.

Consequence: Without documented evidence of outcomes and remediation tracking, recovery preparedness may be difficult to validate.

Likelihood: Medium

Impact: Medium

Risk Rating: Medium

Existing Controls: Annual disaster recovery testing and recovery exercises

Recommended Controls: Review disaster recovery test reports and remediation actions.

Risk Treatment: Mitigate

Residual Risk: Low

Evidence Source: RAG findings and user/vendor follow-up answers

Follow-Up Question:

R005 - Log retention and review evidence should be confirmed

Risk Category: Monitoring and Logging

Cause: System logs are retained for 12 months and reviewed regularly.

Consequence: Weak evidence of logging practices may reduce incident investigation and compliance assurance.

Likelihood: Medium

Impact: Medium

Risk Rating: Medium

Existing Controls: 12-month log retention and regular IT security reviews

Recommended Controls: Review log retention policy and evidence of log review procedures.

Risk Treatment: Mitigate

Residual Risk: Low

Evidence Source: RAG findings and user/vendor follow-up answers

Follow-Up Question:

R006 - SIEM integration is planned but not operational

Risk Category: Monitoring and Logging

Cause: Microsoft Sentinel implementation is planned within the next 12 months.

Consequence: Until SIEM deployment is completed, visibility over security events and incident detection may remain limited.

Likelihood: Medium

Impact: Medium

Risk Rating: Medium

Existing Controls: Microsoft Sentinel planned for deployment

Recommended Controls: Review implementation roadmap and interim monitoring controls.

Risk Treatment: Mitigate

Residual Risk: Low

Evidence Source: RAG findings and user/vendor follow-up answers

Follow-Up Question:

R007 - Third-party assurance evidence should be reviewed

Risk Category: Vendor Risk

Cause: Third-party vendors support hosting, identity, communication and security services.

Consequence: If vendor assurance evidence is incomplete, supply chain, compliance and confidentiality risks may increase.

Likelihood: Medium

Impact: High

Risk Rating: High

Existing Controls: AWS, Azure, Cloudflare and SendGrid with vendor reviews and questionnaires

Recommended Controls: Review vendor assurance evidence, contracts and security responsibilities.

Risk Treatment: Mitigate

Residual Risk: Low

Evidence Source: RAG findings and user/vendor follow-up answers

Follow-Up Question:

R008 - Employee cybersecurity awareness evidence should be reviewed

Risk Category: Vendor Risk

Cause: Cybersecurity training is provided during onboarding and annually.

Consequence: Without evidence of completion and effectiveness, employee-related security exposure may remain.

Likelihood: Low

Impact: Medium

Risk Rating: Low

Existing Controls: Mandatory onboarding and annual cybersecurity training

Recommended Controls: Review training completion reports and awareness programme effectiveness.

Risk Treatment: Mitigate

Residual Risk: Low

Evidence Source: RAG findings and user/vendor follow-up answers

Follow-Up Question:

R009 - Security audit evidence should be reviewed

Risk Category: Vendor Risk

Cause: Internal audits occur annually and external audits occur every two years.

Consequence: Without audit evidence, assurance over security control effectiveness may be reduced.

Likelihood: Low

Impact: Medium

Risk Rating: Low

Existing Controls: Annual internal audits and biennial external audits

Recommended Controls: Review recent audit findings and remediation evidence.

Risk Treatment: Mitigate

Residual Risk: Low

Evidence Source: RAG findings and user/vendor follow-up answers

Follow-Up Question:

R010 - Privacy Impact Assessment evidence should be reviewed

Risk Category: Privacy and Compliance

Cause: PIAs have been conducted for high-risk systems and processes.

Consequence: Without supporting privacy assessment evidence, assurance over privacy risk management may be reduced.

Likelihood: Medium

Impact: High

Risk Rating: High

Existing Controls: Privacy Impact Assessments conducted for high-risk systems

Recommended Controls: Review recent PIA findings and mitigation actions.

Risk Treatment: Mitigate

Residual Risk: Low

Evidence Source: RAG findings and user/vendor follow-up answers

Follow-Up Question: